

Incident Report

Incident Report — Database Ransom / Destruction on corp-gng-940

Report ID: IR-2026-0728-GNG940

Defender Incident ID: 154333 (cyber-defense-corp-gng-940-MySQL)

Analyst: Jason Stokes

Report date: 2026-07-28 (v2: 2026-08-04)

Classification: Ransom / destructive attack on internet-exposed MySQL (data destruction + extortion) **Severity:** High (analyst-assessed) — Defender auto-severity: Medium

Time-zone note: MySQL audit logs (MySQLAudit_CL_*) are timestamped in UTC (Z) and are the authoritative timeline anchor. Defender portal/device times render in UTC-5 (confirmed by the Incident 154333 export header "Timestamps are generated in UTC-5"); host-side rows show portal-local with UTC equivalent (+5h). The offset is independently corroborated at second-level precision: the inbound 3306 connection from 64.89.163.176 renders Jul 27 8:47:14 PM portal-local and the corresponding MySQL auth probe is logged 2026-07-28T01:47:14Z.

Scope note: The shared LAW-Cyber-Range workspace contains an unrelated earlier ransom wave (Jul 23, DATAID 20B23, same BTC wallet). All hunts are constrained to the incident window **2026-07-27T21:00:21Z – 2026-07-28T21:50:51Z** (this incident: DATAID 27VGA).

1. Executive Summary

An internet-exposed MySQL server on host corp-gng-940 was compromised and its databases destroyed by an automated ransom actor. Under five hours after exposure, an attacker at 64.89.163.176 authenticated as root with no password over TCP/3306, briefly inspected the data, dropped all production tables and databases (gng_corp, sakila, world), wiped the binary logs to prevent recovery, planted a Bitcoin ransom note demanding ~0.0134 BTC, and issued SHUTDOWN. Approximately 20 hours later — minutes before containment — a second session from 64.89.163.169 (same /24) re-planted the ransom note with a slightly different demand (~0.0133 BTC). Despite a concurrent RDP brute-force campaign against the Windows host, the host itself was never breached: all host-side telemetry is clean of attacker logons, processes, files, and persistence. The ransom note's claim that data was "backed up by us" is assessed as a bluff

— the mysqld process had no internet egress at any point and no outbound data flows to attacker infrastructure were observed — so the impact is destruction and extortion, not data theft.

2. Incident Details

Field	Value
Affected host	corp-gng-940 (Windows 11 VM, Azure; DeviceId f4306451afca262260d3...)
Affected service	MySQL 8.0 (mysqld.exe) on TCP/3306
Databases destroyed	gng_corp (seeded corporate data), sakila, world
Detection	Scheduled analytics alert cyber-defense-corp-gng-940-MySQL (Defender Incident 154333); manual log review confirmed the destructive activity
Detection date/time	2026-07-28 21:16 UTC (Jul 28 4:16 PM UTC-5) — later of two scheduled-rule firings; first firing 2026-07-27 21:05 UTC
Reported by	Jason Stokes
Incident type	Destructive database ransom (T1485 Data Destruction; extortion). Defender category: Credential Access (TA0006), consistent with the root/weak-credential entry vector
Severity	High — analyst-assessed (total DB loss + anti-recovery actions). Defender auto-severity: Medium
Defender status / classification	Active / Unclassified, Unassigned — recommend True Positive + owner (see §7)
Exposure window opened	2026-07-27T21:00:21Z (analyst-recorded)
VM isolated	2026-07-28T21:50:51Z (analyst-recorded)
Primary attacker IPs	64.89.163.176 (destruction), 64.89.163.169 (final ransom re-plant) — both 64.89.163.0/24

Concurrent (unsuccessful) RDP activity, two distinct patterns:

- **51.11.134.246** — sustained spray: 160 failed logons across ~17 h (22:09Z Jul 27 → 14:52Z Jul 28), 81 unique usernames (dmadmin, clouduser, cloudadmin, sysadmin...). Never succeeded.
- **51.161.196.231** — targeted burst: 40 failed logons in **4 seconds** (22:10:52–56Z Jul 27), single hostname-derived username **gng**. Never succeeded.

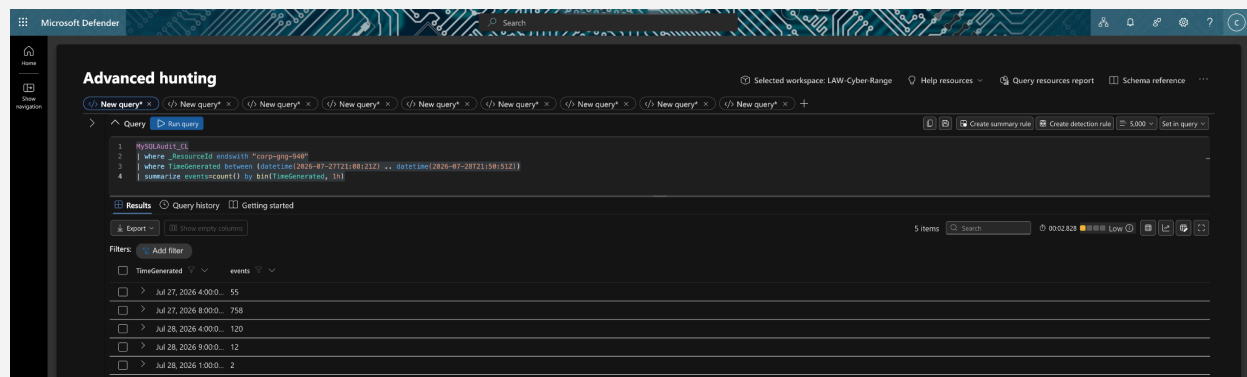
Suggested hunt (scope confirmation):

MySQLAudit_CL

| where _ResourceId ends with "corp-gng-940"

| where TimeGenerated between (datetime(2026-07-27T21:00:21Z) .. datetime(2026-07-28T21:50:51Z))

| summarize events=count() by bin(TimeGenerated, 1h)



3. Impact Assessment

- **Confidentiality — Low / not confirmed.** No exfiltration evidence. DeviceNetworkEvents shows no outbound flows to attacker infrastructure; the **only outbound connection ever initiated by mysqld.exe in the window was loopback (127.0.0.1 → 127.0.0.1)**, so the DB process had no internet egress path for data. All other outbound traffic went to Microsoft/Azure telemetry and update endpoints (sole non-Microsoft destination: ocsf.digicert.com, benign), consistent with the tenant's egress restrictions. Nuance: the attacker did *view* data in-session before destroying it (**SELECT * FROM credentials LIMIT 10** and mysqldump-style introspection at 01:47:22–25Z), but the affected data was non-production seed data including a dummy credentials table, and nothing left the host. The note's "backed up by us" claim is assessed as a bluff.

- **Integrity — Critical.** All tables in gng_corp, sakila, and world were dropped and the databases deleted; a RECOVER_YOUR_DATA database/table was inserted in their place.
- **Availability — Critical.** MySQL was issued SHUTDOWN; binary logs were destroyed (RESET MASTER, PURGE BINARY LOGS TO 'josh-mde-lab-bin.000001'), removing point-in-time recovery. Service was unavailable until remediation.
- **Business impact (lab context):** Total loss of the exposed database. Recovery requires restoration from backup, not decryption. Paying the ransom would almost certainly yield nothing — the data was destroyed, not copied.

Suggested hunt (confirm no exfil):

DeviceNetworkEvents

| where DeviceName == "corp-gng-940"

| where TimeGenerated between (datetime(2026-07-27T21:00:21Z) ..
datetime(2026-07-28T21:50:51Z))

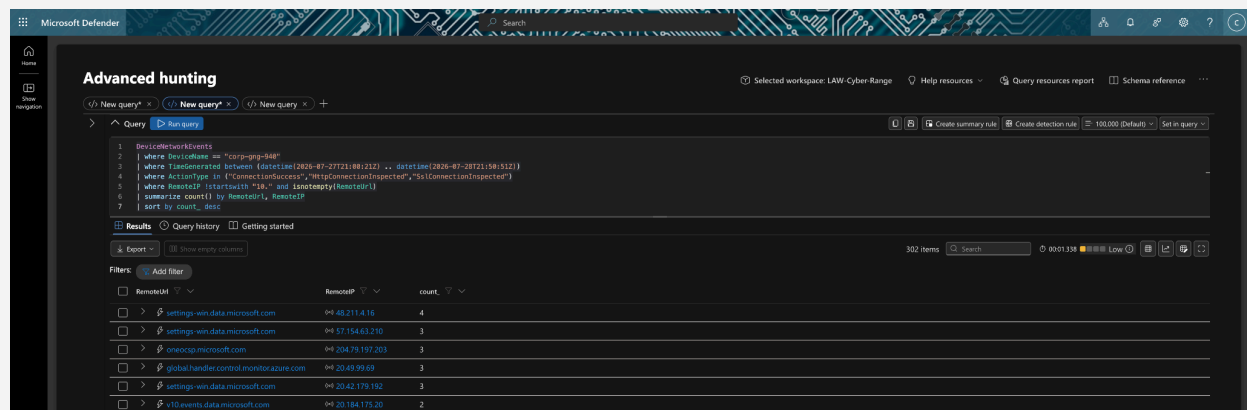
| where ActionType in

("ConnectionSuccess","HttpConnectionInspected","SslConnectionInspected")

| where RemoteIP !startswith "10." and isnotempty(RemoteUrl)

| summarize count() by RemoteUrl, RemoteIP

| sort by count_desc



// mysqld egress specifically — expect loopback only

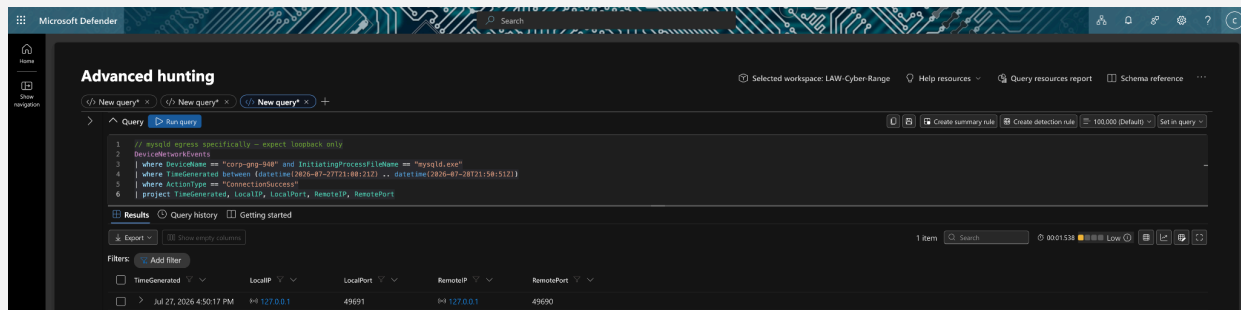
DeviceNetworkEvents

| where DeviceName == "corp-gng-940" and InitiatingProcessFileName == "mysqld.exe"

| where TimeGenerated between (datetime(2026-07-27T21:00:21Z) ..
datetime(2026-07-28T21:50:51Z))

| where ActionType == "ConnectionSuccess"

| project TimeGenerated, LocalIP, LocalPort, RemoteIP, RemotePort



Caption: Sole mysqld-initiated connection in the 25-hour window: loopback 127.0.0.1:49691→49690 at 2026-07-27 21:50:17Z — no internet egress path existed for the DB process.

4. Indicators of Compromise

Type	Indicator	Context
BTC address	bc1qa83x6l2dlgkx7cc9rmrymscp5sa3ljepu42w2r	Ransom payment address in note
Email	ak+27vga@onionmail.org	Attacker contact in note
URL	hxxps://bit[.]ly/22mysql	"More information" link in note
DATAID	27VGA	Victim/campaign ID in note
Attacker IP	64.89.163.176	Root auth + full database destruction (Session 1, 01:47–01:48Z)
Attacker IP	64.89.163.169	Root auth + final ransom re-plant (Session 2, 21:47Z)
Attacker subnet	64.89.163.0/24	Both attacker IPs; likely same operation
IP (probe)	35.233.78.91	Single failed MySQL root auth, 18:17Z Jul 28 (probe only)

IP (RDP spray)	51.11.134.246	160 failed RDP logons, 81-username spray — never succeeded
IP (RDP burst)	51.161.196.231	40 failed RDP logons in 4 s, username gng — never succeeded
Malicious DB/table	RECOVER_YOUR_DATA	Ransom-note container created on the server

Behavioral fingerprint: each successful attacker session was immediately preceded by one or two **Access denied for user 'root'@'<ip>' (using password: NO)** probes — a high-fidelity precursor (see §9.6).

The ransom note recovered from the attacker-created recover_your_data database contains all four note-based IOCs (BTC address, bit.ly link, onionmail contact, DATAID), confirming a single, consistent extortion message. Demand drifts 0.0134 BTC (Session 1) → 0.0133 BTC (Session 2).

Suggested hunt (IOC sweep, scoped to incident window):

MySQLAudit_CL

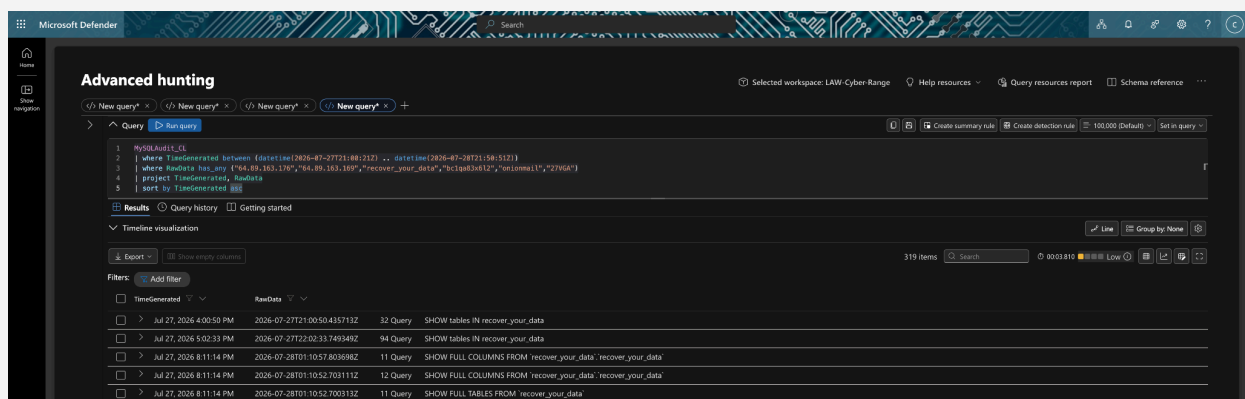
| where TimeGenerated between (datetime(2026-07-27T21:00:21Z) ..
datetime(2026-07-28T21:50:51Z))

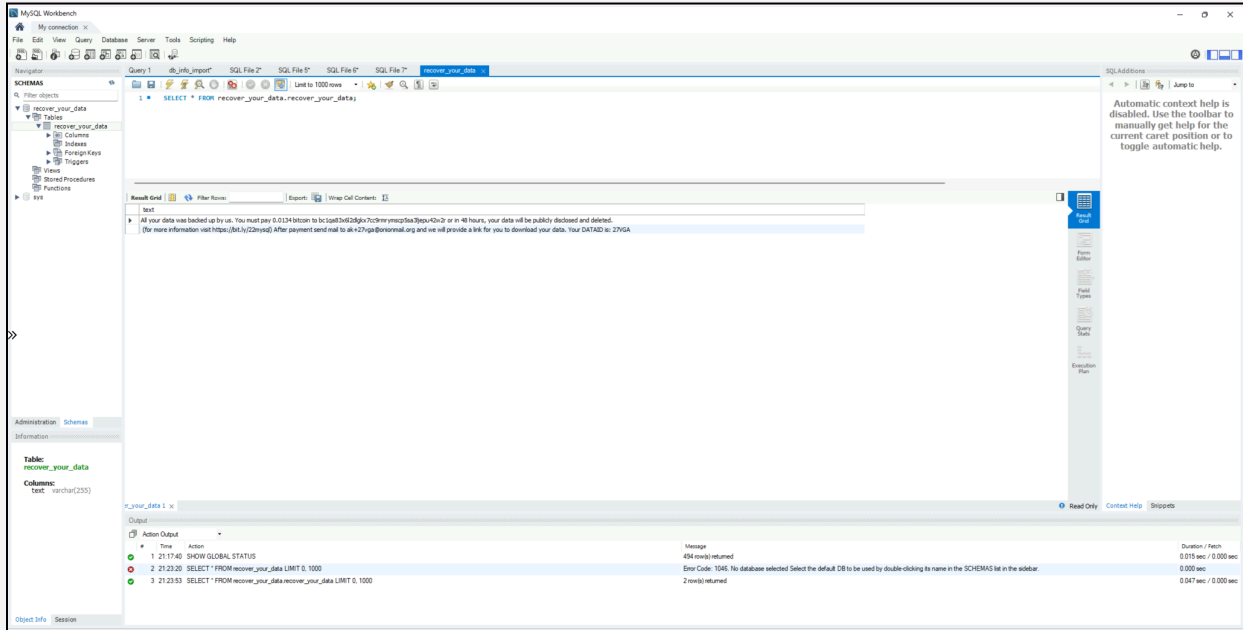
| where RawData has_any

("64.89.163.176","64.89.163.169","recover_your_data","bc1qa83x6l2","onionmail","27VGA")

| project TimeGenerated, RawData

| sort by TimeGenerated asc





5. Timeline (UTC)

Each row cites the source table. MySQL rows are exact UTC; host/device rows show portal-local (UTC-5) with UTC equivalent.

Time (UTC)	Event	Source
07-27 21:00:21	Exposure window opened (NSG allow-all inbound) — analyst-recorded	Lab record
07-27 21:05:32	CREATE USER 'root'@'%' + GRANT ALL — defender weakening step (localhost session, conn 42)	MySQLAudit_CL_Query
07-27 21:17:17	Windows Firewall disabled, EnableFirewall=0 on all three profiles (Domain/Standard/Public) — defender weakening step (4:17:17 PM UTC-5)	DeviceRegistryEvents
07-27 22:09:06	RDP spray begins from 51.11.134.246 (5:09 PM UTC-5)	DeviceLogonEvents

07-27 22:10:52–5 6	RDP burst from 51.161.196.231 — 40 attempts / 4 s, username gng	DeviceLogonEvents
07-27 → 07-28	TCP/3306 inbound connections from ~21 distinct internet scanner IPs	DeviceNetworkEvents
07-28 01:47:14–2 0	Two Access denied ... (using password: NO) probes from 64.89.163.176; inbound 3306 connection accepted 01:47:14	MySQLAudit_CL_Auth; DeviceNetworkEvents
07-28 01:47:21	64.89.163.176 authenticates as root (blank password); 73 parallel connections through 01:48:59 — automated tooling	MySQLAudit_CL_Auth
07-28 01:47:22–2 5	Pre-destruction recon: information_schema enumeration; SELECT * FROM credentials LIMIT 10	MySQLAudit_CL_Query
07-28 01:47:34–3 5	gng_corp tables dropped (payments, orders, customers, credentials); ransom note planted in-schema	MySQLAudit_CL_Query
07-28 01:48:43–5 5	sakila (store, staff_list, ...) and world (countrylanguage, country, city) tables dropped; notes planted	MySQLAudit_CL_Query
07-28 01:48:55–5 6	DROP DATABASE gng_corp / sakila / world	MySQLAudit_CL_Query
07-28 01:48:57	CREATE DATABASE RECOVER_YOUR_DATA + full ransom note (0.0134 BTC, DATAID 27VGA)	MySQLAudit_CL_Query
07-28 01:48:58–5 9	RESET MASTER; PURGE BINARY LOGS (anti-recovery); REVOKE from root@'%'; SHUTDOWN	MySQLAudit_CL_Query

07-28 01:49 → 21:16	No attacker activity evidenced. No external logons, no data-modifying queries; recurring monitoring SHOW queries (detection pipeline polling for recover_your_data) continue through the gap	MySQLAudit_CL_Auth/_Query; live MySQLAudit_CL
07-28 14:24:07	mysqld restarts (startup log: "TCP Port: 3306" banner + performance_schema init) — ~12.5 h after attacker SHUTDOWN; restart mechanism not determined (see §6, Marked unknown)	MySQLAudit_CL (live, 14:00Z-bin drill-down)
07-28 14:52:42	Last RDP spray failure — campaign never succeeded (9:52 AM UTC-5)	DeviceLogonEvents
07-28 18:17:00	Failed root probe from 35.233.78.91 (password: NO) — no success	MySQLAudit_CL_Auth
07-28 21:16	Second scheduled-rule firing (Incident 154333) — detection; analyst Workbench review session begins 21:16:59 (conns 19/20)	Defender alert; MySQLAudit_CL_Query
07-28 21:47:44–5 8	Session 2: probes then 11 root logons from 64.89.163.169; ransom DB dropped and re-planted (0.0133 BTC)	MySQLAudit_CL_Auth/_Query
07-28 21:50:51	VM isolated in Microsoft Defender — analyst-recorded	Lab record

Correction vs. v1: v1 listed intermediate re-plant cycles at 03:10, 03:11, 16:51, 18:12, and 19:08 UTC. These are **not corroborated by any provided source**: MySQLAudit_CL_Auth records no logons and MySQLAudit_CL_Query no statements between 01:48:59Z and 21:16:59Z, and the Incident 154333 export records no activity at those times. Exactly **two** attacker write-sessions are evidenced. The intermediate timestamps are withdrawn; if they originated from another artifact, that artifact should be attached as evidence before reinstating them.

Suggested hunt (destruction sequence, scoped to incident window):

MySQLAudit_CL

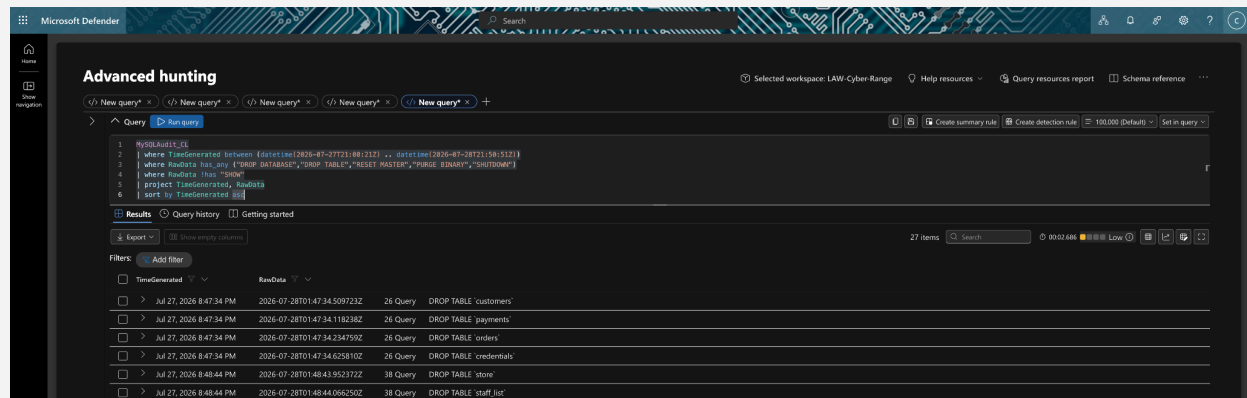
| where TimeGenerated between (datetime(2026-07-27T21:00:21Z) ..
datetime(2026-07-28T21:50:51Z))

| where RawData has _any ("DROP DATABASE","DROP TABLE","RESET MASTER","PURGE BINARY","SHUTDOWN")

| where RawData !has "SHOW"

| project TimeGenerated, RawData

| sort by TimeGenerated asc



6. Root Cause / Attack Vector

Root cause: An internet-exposed MySQL service (TCP/3306) permitted root authentication over the network with a blank password (root@'%'). **Access denied ... (using password: NO)** probes immediately preceded successful connects in both attacker sessions, confirming a no-credential login (matching Defender's Credential Access categorization). With root and ALL PRIVILEGES, the actor had full control to drop data and wipe recovery logs.

Contributing exposure factors: NSG opened to all inbound; Windows Firewall disabled on all profiles (21:17:17Z); MySQL bound to the network with a privileged, unauthenticated account.

What did NOT happen (explicitly ruled out):

- **The Windows host was not compromised.** Zero LogonSuccess events from any public IP (success sources: local/console and internal 10.x only; accounts jstokes + dwm-/umfd-). No processes ran as administrator or guest; no account-creation commands; no attacker files, dropped executables, registry persistence (Run/RunOnce/Winlogon/Services/IFEO all clean), or RDP-config tampering. Both RDP sources failed throughout.
- **No SQL-to-OS pivot.** mysqld.exe spawned zero child processes and initiated zero file events — no INTO OUTFILE webshell, UDF, or command execution. The compromise stayed inside MySQL.

- **No in-database persistence.** No CREATE EVENT, CREATE TRIGGER, or CREATE PROCEDURE statements anywhere in the query log.
- **No exfiltration** (see §3).

Marked unknown (not determined from available logs):

1. **How mysqld restarted after the attacker's SHUTDOWN (01:48:59Z).** Restart **time** is now identified: the live MySQLAudit_CL captures the mysqld startup log at **2026-07-28T14:24:07Z** ("TCP Port: 3306, Named Pipe: MySQL" banner + internal performance_schema initialization) — ~12.5 h after the SHUTDOWN and ~7 h before detection. This also explains the low/non-monotonic connection IDs in the evening sessions (19/20 analyst, 30–35 attacker Session 2). The restart **mechanism** (Windows service recovery vs. manual/scheduled) remains not determined from available logs — no mysqld.exe process-start appears in DeviceProcessEvents. Connection IDs additionally imply one earlier pre-attack restart (~22:02Z–01:10Z).
2. **Whether any non-monitoring activity occurred between 01:49Z and 21:16Z.** The extracted auth/query tables show none. The live MySQLAudit_CL contains recurring detection-pipeline SHOW queries through the gap; drill-down on the 14:00Z bin identified its 12 events as the **mysqld startup log at 14:24:07Z** (server restart), not attacker activity:

MySQLAudit_CL

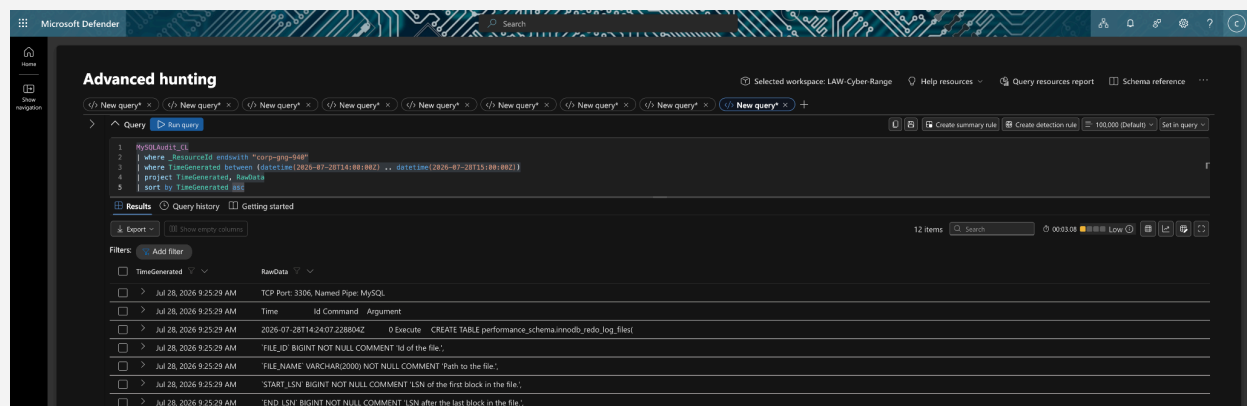
| where _ResourceId ends with "corp-gng-940"

| where TimeGenerated between (datetime(2026-07-28T14:00:00Z) ..

datetime(2026-07-28T15:00:00Z))

| project TimeGenerated, RawData

| sort by TimeGenerated asc



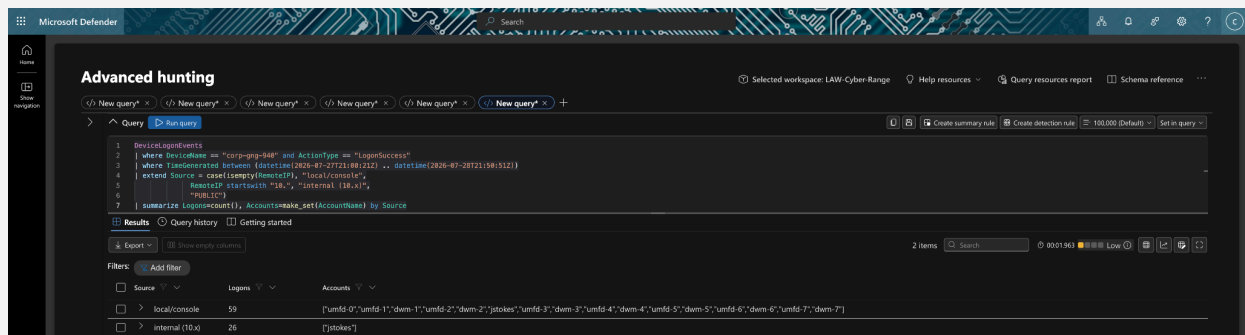
3. **Whether the two attacker IPs represent one actor or two.** Same /24, identical note text and tooling behavior strongly suggest a single operation/toolkit, but this is inference.

Suggested hunt (confirm host was not breached):

DeviceLogonEvents

```
| where DeviceName == "corp-gng-940" and ActionType == "LogonSuccess"  
| where TimeGenerated between (datetime(2026-07-27T21:00:21Z) ..  
datetime(2026-07-28T21:50:51Z))  
| extend Source = case(isempty(RemoteIP), "local/console",  
    RemoteIP startswith "10.", "internal (10.x)",  
    "PUBLIC")  
| summarize Logons=count(), Accounts=make_set(AccountName) by Source
```

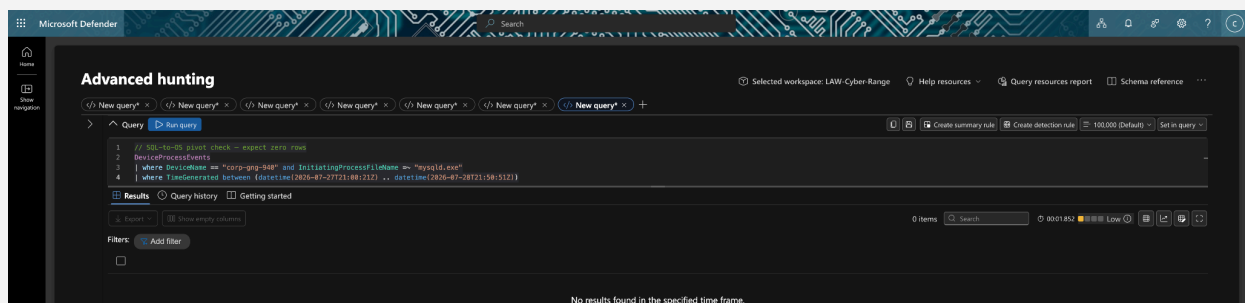
Expected: local/console and internal (10.x) rows only; **no PUBLIC row** — the absent PUBLIC bucket is the affirmative evidence that no internet-based logon ever succeeded



// SQL-to-OS pivot check — expect zero rows

DeviceProcessEvents

```
| where DeviceName == "corp-gng-940" and InitiatingProcessFileName =~ "mysqld.exe"  
| where TimeGenerated between (datetime(2026-07-27T21:00:21Z) ..  
datetime(2026-07-28T21:50:51Z))
```



7. Response Actions

Containment (taken):

- VM isolated in Microsoft Defender at 2026-07-28T21:50:51Z.
- A second Defender Investigation Package captured post-isolation for before/after comparison.

Eradication (recommended / taken):

- Rebuild or fully re-image the VM (data-destructive attack; treat DB as unrecoverable in place).
- Remove the network-reachable root@'%' account; disable remote root entirely.
- Delete the RECOVER_YOUR_DATA database/table artifact, **and enumerate/drop any attacker-created events, triggers, or stored routines** (none observed in the audit log, but verify on the live instance; re-imaging moots this).

Recovery (recommended):

- Restore gng_corp from the Phase-2 backup; re-import sakila/world from MySQL sample sources.
- Binary logs were destroyed (RESET MASTER / PURGE BINARY LOGS), so point-in-time recovery is not possible — restore is limited to the last full backup.
- **Do not pay.** Data was destroyed, not exfiltrated; payment would not restore it.

Case management:

- Classify Incident 154333 as **True Positive** in Defender (currently Active / Unclassified / Unassigned) and assign an owner. The scheduled alert attached no entity evidence ("No evidence was found for this incident"), which is why the MySQL audit logs were hunted manually — see §9.5.

Hardening before re-exposure:

- Restrict NSG to required source ranges only; never expose 3306 to the internet.
- Re-enable Windows Firewall; enforce strong, unique DB credentials; bind MySQL to localhost or a private subnet.

8. Evidence

Artifact

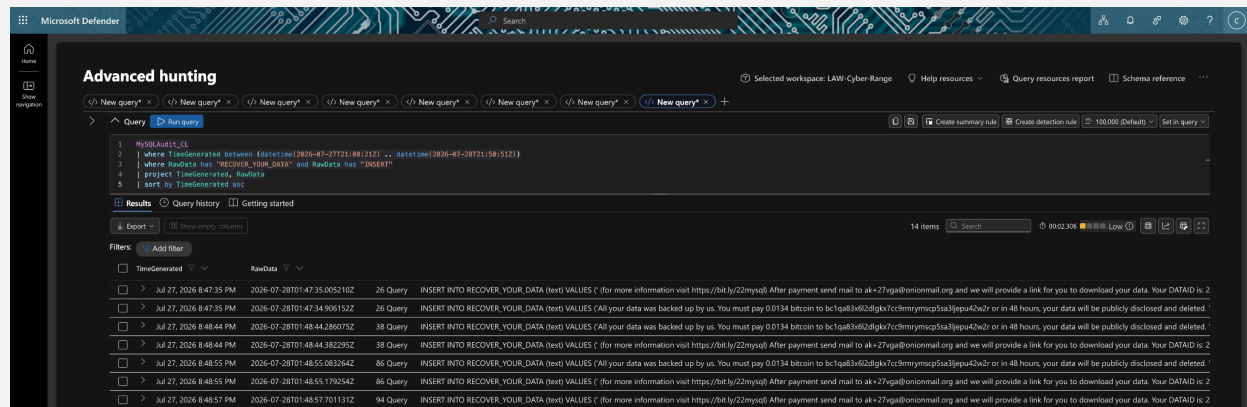
Role in investigation

Defender Incident 154333 export (Incident_154333.pdf)	Scheduled alert that surfaced the incident; Credential Access category; two firings (21:05Z Jul 27, 21:16Z Jul 28); "No evidence was found"; UTC-5 rendering confirmed
MySQLAudit_CL_Auth.csv	93 root auth events: denied(password: NO)→success pattern; Session 1 (64.89.163.176, 73 conns, 01:47–01:48Z) and Session 2 (64.89.163.169, 11 conns, 21:47Z); 35.233.78.91 probe; no logons 01:49–21:47Z
MySQLAuth_CL_Query.csv	696 statements: setup (CREATE USER/GRANT), recon SELECTs, DROP TABLE/DATABASE, RESET MASTER, PURGE BINARY LOGS, REVOKE, SHUTDOWN, ransom-note INSERTs (both sessions); analyst Workbench session 21:16–21:23Z (conns 19/20)
DeviceNetworkEvents.csv	3306/3389 inbound exposure (~21 scanner IPs); attacker inbound connections matching auth times to the second; mysqld outbound = loopback only; no outbound C2/exfil
DeviceLogonEvents.csv	RDP spray (51.11.134.246, 160) and burst (51.161.196.231, 40); zero public-IP successes
DeviceProcessEvents.csv	No attacker processes; zero mysqld child processes; no account creation. Triage note: recurring net localgroup / wevtutil epl Security executions are mssense.exe (Defender sensor) self-inventory on a fixed cadence — benign, not attacker recon
DeviceFileEvents.csv	No host encryption, ransom-note files, or dropped executables; no mysqld-initiated file events; deletions are OS housekeeping
DeviceRegistryEvents.csv	EnableFirewall=0 on all three profiles at 21:17:17Z (defender step); no attacker persistence in Run/Services/Winlogon/IFEO
Defender Investigation Packages	Pre- and post-isolation host state for comparison

Reference — ransom-note retrieval (scoped to incident window):

MySQLAudit_CL

| where TimeGenerated between (datetime(2026-07-27T21:00:21Z) ..
datetime(2026-07-28T21:50:51Z))
| where RawData has "RECOVER_YOUR_DATA" and RawData has "INSERT"
| project TimeGenerated, RawData
| sort by TimeGenerated asc



9. Lessons Learned / Recommendations

Prioritized:

1. **Never expose database services to the internet.** Bind MySQL to localhost/private subnet; restrict TCP/3306 at the NSG to explicit admin source IPs. (Would have prevented this incident outright — first attacker session landed <5 h after exposure.)
2. **Eliminate weak/remote privileged DB accounts.** No root@'%'; enforce strong, unique passwords and least-privilege accounts; disable remote root. (Directly addresses the root cause: blank-password root.)
3. **Close the detection gap on destructive DB actions.** The scheduled rule fired at 21:05Z Jul 27 and 21:16Z Jul 28, bracketing the 01:47Z destruction without catching it. Add near-real-time alerting on DROP DATABASE, DROP TABLE, RESET MASTER, PURGE BINARY LOGS, SHUTDOWN, and creation of RECOVER_YOUR_DATA-style artifacts.
4. **Protect recovery data.** Ship binary logs and backups off-box to write-once/immutable storage so RESET MASTER / PURGE BINARY LOGS cannot destroy recovery capability; test restores.
5. **Enrich alerts with entity evidence.** Incident 154333 attached no evidence, forcing manual log hunting. Map the scheduled rule's entities (IP, account, database) so future alerts are actionable on sight.

6. **Alert on external MySQL auth failures/successes.** **Access denied ... (using password: NO)** from a public IP immediately preceding a successful root connect occurred in both attacker sessions — a high-fidelity early indicator worth a dedicated analytic.
 7. **Keep host hardening on.** Windows Firewall enabled and NSG least-privilege by default; the disabled firewall (all three profiles, 21:17:17Z) widened the attack surface.
-

Appendix — Changes from v1 (verification against source logs, 2026-08-04)

#	Section	Change	Basis
1	§1, §5	Withdrew intermediate re-plant cycles (03:10, 03:11, 16:51, 18:12, 19:08 UTC); exactly two attacker write-sessions are evidenced. Removed "automatically ... in repeated cycles" framing	No auth or query rows exist 01:49–21:16Z in either MySQL audit table; no matching activity in Incident 154333 export
2	§5, §6	Added Marked unknown: mysqld restart mechanism after SHUTDOWN	No mysqld.exe process-start in DeviceProcessEvents; no other source
3	§6	Added explicit rule-out: no in-database persistence (EVENT/TRIGGER/PROCEDURE)	Zero such statements in query log
4	§2, §4, §5	Split RDP activity into sustained spray (51.11.134.246) vs 4-second targeted burst (51.161.196.231, username gng)	DeviceLogonEvents timing
5	§3	Added strongest no-exfil datum: mysqld's only outbound connection was loopback	DeviceNetworkEvents
6	§3, §5	Added pre-destruction recon (SELECT * FROM credentials LIMIT 10 , information_schema dumps) with confidentiality nuance	MySQLAuth_CL_Query 01:47:22–25Z
7	§7	Eradication extended to attacker-created events/triggers/routines check	Completeness

8	§8	Added triage note on benign mssense.exe "suspicious-looking" telemetry	DeviceProcessEvents
9	Header, §5	Tightened timezone corroboration (second-level cross-source match); firewall-disable time made exact (21:17:17Z, all three profiles)	DeviceNetworkEvents + MySQLAudit_CL_Auth; DeviceRegistryEvents
10	§5, §6	Post-screenshot verification: gap wording corrected — live MySQLAudit_CL shows recurring detection-pipeline SHOW queries through the 01:49–21:16Z gap (absent from CSV extracts); added 14:00Z-bin drill-down as open item	IOC-sweep and scope-confirmation hunt screenshots, 2026-08-04
11	§6	Restart inference added: non-monotonic connection IDs imply ≥ 2 mysqld restarts (pre-attack and post-SHUTDOWN); mechanism still unlogged	Live MySQLAudit_CL connection IDs
12	§3	Caption added under mysqld-egress evidence image (sole connection = loopback, 21:50:17Z Jul 27)	Verified hunt screenshot
13	§5, §6	14:00Z-bin drill-down identified the 12 events as the mysqld startup log — restart time pinned to 14:24:07Z Jul 28; restart mechanism remains Marked unknown	14:00Z drill-down hunt screenshot, 2026-08-04

DFIR Analysis

MDE Package Comparison — corp-gng-940 (DFIR Host-Artifact Analysis)

Companion to Incident Report IR-2026-0728-GNG940. Analysis date: 2026-08-04. Two MDE live-response packages compared; no incident type assumed.

1. Baseline Determination

Baseline = Pre_Breach package; comparison = Post_Breach package.

Basis: collection-summary internal timestamps — pre collected **2026-07-27T21:09:02Z**, post **2026-07-28T21:05:29Z**([Forensics Collection Summary.csv](#) in each). Corroborated by (a) distinct CollectedData GUID folders, and (b) System Boot Times ([SystemInformation.txt](#)): pre boot 7/27 14:03, post boot 7/28 14:23. Same host CORP-GNG-940, same interface 10.1.0.112. The post package was captured ~45 min before VM isolation (21:50:51Z), so it reflects fully-compromised host state — the strongest possible test for host-level attacker traces.

2. Summary Verdict

Compromise indicators (host level): NO — high confidence. Every persistence, account, service, task, and process surface is identical between packages apart from routine OS churn. The only real deltas are external RDP brute-force noise against port 3389 — all failed. No successful public logon, no new persistence, no privilege change, no log clearing. This independently corroborates the incident report's "host was never breached" finding from a second evidence source. (Note: the actual DB destruction occurred *inside MySQL* and is not expected to surface in host artifacts — see Gaps.)

3. Table of Notable Deltas

Category	Item	Change type	Benign vs Suspicious	Evidence
Autoruns / Run keys	HKLM + jstokes Run/RunOnce	UNCHANGED	benign	Autoruns.txt — identical OneDrive, MicrosoftEdgeAutoLaunch, SecurityHealth

Scheduled tasks	task-name set	CHANGED (-\\Setup\\SetupCleanup Task)	benign	ScheduledTasks.csv ; self-removing OS task; all others only trigger/last-run churn
Services / drivers	service-name set	UNCHANGED	benign	Services.csv ; only per-session suffix _122408 → _dcfb5 and PID reassignment
Processes	process-name set, mysqld present ×2	UNCHANGED	benign	Processes.csv ; only transient app PIDs differ
Local users	accounts, incl. Administrators group	UNCHANGED	benign	LocalGroups.txt — Administrators = {administraor, jstokes} in both; administraor created 7/26 (pre-baseline)
Listening ports	3306, 3389, 33060, 135/139/445, 5040	UNCHANGED	benign (but exposed)	ActiveNetConnections.txt — identical listeners on 0.0.0.0
Network — inbound 3389	brute-force source IPs	CHANGED	suspicious (failed)	pre: 80.94.95.83, 103.117.186.132; post: 51.161.196.231, 51.11.134.246, 80.66.83.43
Security event log	4625 failures 2,543 → 15,377	CHANGED (growth)	suspicious (failed)	Security.evtx ; 1102 log-cleared = 0 (not tampered)
Installed programs	program list	UNCHANGED	benign	InstalledPrograms.csv — identical
Hosts / DNS / ARP	resolver + neighbor state	UNCHANGED	benign	DnsCache.txt all Microsoft; Arp.txt only interface-index change
Firewall rules	host firewall log	UNCHANGED (both empty)	benign-collection	FirewallExecutionLog.txt — pfirewall.log not found in both (logging off)
Loaded modules / DLLs	—	N/A	—	not included in MDE live-response package set

Browser / credential artifacts	—	N/A	—	not present in either package
--------------------------------	---	-----	---	-------------------------------

4. Prioritized Compromise Indicators → ATT&CK

All indicators are **attempted, not successful**:

- T1110 Brute Force (Credential Access)** — post 4625 failures = 15,377 vs pre 2,543. 51.161.196.231 = 11,389 attempts against user **CORP**; 51.11.134.246 = 2,722 username spray. Source: **Security.evtx**. Matches the incident report's two named RDP IPs exactly (independent second-source confirmation).
- T1190 Exploit Public-Facing Application (surface)** — 3306 (mysqld) and 3389 (RDP) listening on 0.0.0.0 in both packages. Source: **ActiveNetConnections.txt**.
- No successful counterpart (explicit negative)** — the only external 4624 "successes" are **ANONYMOUS LOGON**Type-3 NTLM null sessions (46.105.132.55 @07:26Z, 35.205.92.76 @16:44Z) — negotiation artifacts, not access. All credentialed logons are jstokes from 10.0.8.x. No 4720 (account created — the one in pre is **administraor** at lab-setup, pre-baseline), no 4732 (group add), no 7045 (new service), no 4698 (new task), no 1102 (log cleared).

5. Probable Incident Type

From host artifacts alone: failed external RDP brute-force against an internet-exposed host — no host compromise. The host layer shows no ransomware, persistence, or data-theft tooling. Letting the evidence speak: at the OS level the story is *attempted access, unsuccessful*. This does not reveal the true incident (MySQL data destruction), which occurred entirely within the database service and is invisible to these artifacts — correctly, the packages neither manufacture nor contradict it.

6. Step 4 — IOC List and Baseline Cross-Check

IOCs derived from the post package, then grepped across both:

Indicator	Type	In post?	In baseline (pre)?	Assessment / ATT&CK
51.161.196.231	IP	Yes (11,389× 4625)	No	RDP burst, user gng/CORP — T1110

51.11.134.246	IP	Yes (2,722× 4625)	No	RDP spray, 81 usernames — T1110
80.66.83.43	IP	Yes (1,228× 4625)	No	RDP brute, failed — T1110
80.94.95.83	IP	No	Yes (1,724× 4625)	Baseline-era brute (earlier Jul-23 wave adjacent); failed
103.117.186.132	IP	No	Yes (814× 4625)	Baseline-era brute; failed
46.105.132.55 / 35.205.92.76	IP	Yes (ANON LOGON)	No	Null-session enum, not access
administraor	account	Yes (Admins)	Yes (Admins)	Present in both — pre-existing lab admin, NOT attacker-added
RECOVER_YOUR_DATA / 64.89.163.0/24 / BTC / onionmail	DB-layer IOCs	No	No	Confirms host artifacts carry no MySQL-attack trace

Cross-check conclusion: every suspicious IOC is a **failed external brute-force source**; none corresponds to host access, and the post-package brute IPs are cleanly **absent from baseline** (distinct from the baseline's own earlier failed-brute IPs). No attacker-added account, service, task, or persistence exists in either package.

Gaps: MySQL-layer activity is invisible to host artifacts (by design — primary evidence is MySQLAudit); host firewall log absent in both (logging disabled, so rule-diff impossible); prefetch/MFT not in the MDE package set (recently-created-executable check relied on processes/autoruns/services, all clean); only the Security channel is present (no System/Application evtv to cross-check the 14:24Z mysqld restart or service-control events).
